Trust, Accounts and the Cross-Account Contract

How the messaging system is divided so that one tenant cannot reach another, and what the only permitted path between two accounts is. This sheet shows the mechanism: the trust chain that issues identity, the account plane that isolates, the subject families the platform speaks in, and the export and import grants that let a named subject cross a boundary. Exact subjects, stream settings and permission claims belong to L4.

TRUST CHAIN · OPERATOR-SIGNED, NOTHING LISTED ON THE SERVER

O · Operator
the single trust root
`signs every account claim`
`one signing key, held apart`

A · Account claim
one per isolation boundary
`a signed token, not config`
`minted by the control plane`

U · User credential
one holder, one credential
`named for the process`
`a browser gets a token`

WHERE THE CLAIMS LIVE

R · Account resolver
signed tokens on disk
`no account list in`
`the server config file`

C · Claim push
over the system API
`add or revoke live`
`no server restart`

operator-signed claims define each account

served when a client connects

ACCOUNT PLANE · ONE ACCOUNT PER ISOLATION BOUNDARY

S · System account
server and claim admin
`one holder: the accounts service`
`carries no business traffic`

K · Control account *(dashed: proposed, not built)*
control-plane services
`NATS provisioning, identity`
`collector; Grafana if hosted`

P · Platform account
shared data services
`reference data, registry`
`every tenant imports from it`

T · Tenant account
the hard isolation boundary
`own streams, key-value, files`
`cannot see another tenant`

N · Tenant account, next
added while running
`claim minted, pushed, used`
`no restart, no config edit`

every subject is published inside one account

SUBJECT FAMILIES · THE VOCABULARY THE GRANTS ARE WRITTEN IN

E · evt.
durable domain facts
`evt.{context}.{service}.`
`stays inside its account`

R · rpc.
service to service
`rpc.{context}.{svc}.{op}.v1`
`crosses only by a grant`

A · api.
browser to service
`api.{context}.{svc}.{op}.v1`
`never given to a backend`

N · notify.
change notification
`notify.{context}.{what}`
`replaces server-sent events`

O · obs.
debug side channel
`obs.trace. and obs.pubsub.`
`never on a business path`

only the subjects a grant names may cross

CROSS-ACCOUNT CONTRACT · THE ONLY PATH BETWEEN TWO ACCOUNTS

D · Reference data, down
the platform account exports, each tenant imports
`the tenant calls a plain local subject; the remap is hidden`
`one shared corpus, not a copy for every tenant`

U · Telemetry and stream views, up
each tenant exports, the platform account imports
`the server writes the tenant name into the subject`
`read-only views; a client cannot forge the name`

X · Everything else is refused
no grant means no delivery, and no clue to guess from
`create, update, purge and delete are never exported`
`no tenant can name another tenant's subject`

! · Isolation is enforced by the server, not by application code
signed claims · one account per boundary · explicit export and import · subject-safe identifiers only
`a subject token never carries the tenant or the region: the account carries the tenant, the deployment carries the region`

Read it downward. The operator issues identity, the resolver holds it, the account plane spends it, the subject families name what is spoken, and the contract row is the only opening in the wall. Everything drawn here runs today in the Dictionary POC with four accounts and live tenant creation. The one exception is the dashed **control account**: it is proposed and not built. **Not shown:** individual subjects, permission claim text and stream settings — those are `L4` .

SCOPE	**One question.** How does messaging keep tenants apart, and what may cross? Server placement and durable state are on sheet 2.
TRUST	The **operator** is the only root. It signs account claims; each account signs its own users. A server holds no list of accounts.
ACCOUNT	An **account is the isolation boundary**. It is not a region, and it is not a business context. Treat it as the tenant wall.
CONTEXT	`{context}` is the company or business unit and sits in the subject. The tenant sits in the account. The region sits in the deployment.
IMPORT	A tenant reaches shared reference data through an **import**, then calls it as an ordinary local subject. It never learns the platform subject.
EXPORT	A tenant **exports** telemetry and read-only stream views. The server rewrites them under a monitor prefix that carries the tenant name.
DENY	**No grant means no delivery.** Stream create, update, purge and delete are never exported, so a console can read but not damage.
CREDS	One credential per holder, named exactly as the process names itself. A name that does not match in the console is a signal to check.
BROWSER	A browser **never** holds a credentials file. It gets a short-lived token over a web socket through the web server.
LAB	Proven in the Dictionary POC: four accounts, per-account signing keys, live tenant creation, and the exact grant shape drawn here.

LEGEND

- Green boundary — trust and identity issue
- Solid tile — element built and running in the lab
- Blue line — a direct, answered exchange
- Letter badge — a picture cue only; the words carry the meaning
- Cyan boundary — account plane, the isolation wall
- Dashed tile — proposed for V3, not built today
- Amber dashed line — a message sent without waiting
- Blue boundary — subject vocabulary
- Amber panel — a rule that governs the whole sheet
- Arrow head — the direction of the relationship
- Amber boundary — claim storage and cross-account grants
- Green line — identity or claim is granted
- Line label — names the relationship, never bare "uses"

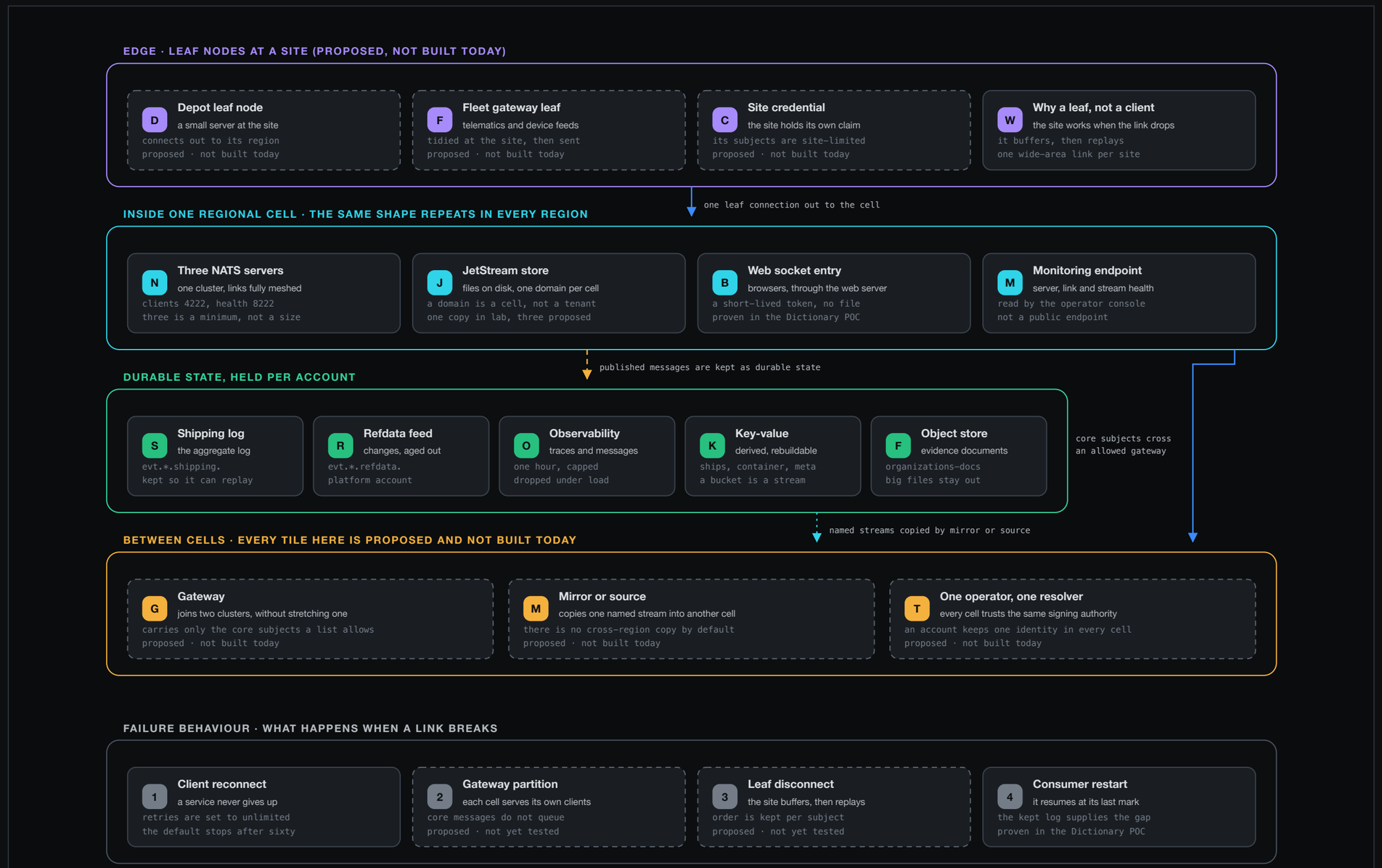
WORDS ON THIS SHEET

NATS the messaging system (a product name)
JWT JSON Web Token, a signed claim
API application programming interface
RPC remote procedure call
POC proof of concept (the Dictionary POC)
claim a signed statement of who you are
creds a credentials file: claim plus key
grant an export matched by an import
subject the address a message is sent to
remap the server rewriting a subject
{context} company or business unit token
{tenant} the account name the server inserts

Traceability: L3-05-001 to L3-05-014 and L3-05-035 to L3-05-036 (trust chain, account plane with the control and platform accounts, subject families, cross-account grants). Parent: LB-V3-L2-01 requirement L2-D04. Related: LB-V3-L3-09 Security and Identity for permission policy and audit.

Server Topology, Durable State and Failure Behaviour

Where the messaging servers run, how a site at the edge attaches, what durable state each account holds, how two regions are joined, and what happens when a link breaks. Solid tiles are built and running in the Dictionary POC on a single server. Dashed tiles are proposed for V3 and are not built today. Residency, recovery targets and country rules belong to LB-V3-L3-08; sizing and configuration values belong to L4.



Read it downward. A site attaches to a cell, the cell keeps the durable state, and only named traffic leaves the cell for another region. **Built today:** one server, one cell, one copy of each stream. **Not built:** every dashed tile — clusters, gateways, mirrors and leaf nodes. **Not shown:** sizing, stream settings and country rules — those are `L4` and `LB-V3-L3-08`.

SCOPE	**One question.** Where do the servers run and what durable state do they hold? Residency and recovery targets are `LB-V3-L3-08`.
CELL	A **cell** is one region's runtime. The same shape repeats in each region. A cell is a place, not a tenant.
HA	Three servers is the **availability minimum**, not a capacity estimate. How big each one is stays open until sizing work is done.
DOMAIN	A JetStream **domain** marks a cell. It is not a tenancy boundary. The account is the tenancy boundary (sheet 1).
GATEWAY	A **gateway** joins two clusters. It does not stretch one cluster over a long link. Only listed core subjects cross it.
MIRROR	Durable history crosses a region only as a **named mirror or source**. There is no cross-region copy by default.
LEAF	A **leaf node** lets a depot keep working while the link is down, then replay. Nothing like this is built today.
STATE	Streams keep facts. Key-value keeps derived reads. The object store keeps large files. They are **not** interchangeable.
REPLAY	Streams keep a **limits** policy so history can be replayed. An interest policy would delete the history instead.
OPEN	Whether two regions get a gateway at all, and which subjects may cross it, is **not decided**. See the L3-05 register.

LEGEND

- **Purple boundary** — the edge, away from a data centre
- **Grey boundary** — behaviour, not a component
- **Amber dashed line** — a message kept as durable state
- **Cyan boundary** — the runtime inside one region
- **Solid tile** — built and running in the lab today
- **Cyan dotted line** — a copy of a stream, not the original
- **Green boundary** — durable state that survives a restart
- **Dashed tile** — proposed for V3, not built today
- **Arrow head** — the direction of the relationship
- **Amber boundary** — links between two regions
- **Blue line** — a live connection between servers
- **Line label** — names the relationship and its transport

WORDS ON THIS SHEET

- **NATS** the messaging system (a product name)
- **JetStream** the part of NATS that stores messages
- **HA** high availability, keeping running through a fault
- **cell** one region's complete runtime
- **cluster** servers linked as one, in one place
- **gateway** a link joining two clusters
- **leaf node** a small server at a site, linked to a cell
- **domain** a JetStream name marking one cell
- **stream** a kept, replayable log of messages
- **consumer** a named reading position on a stream
- **mirror / source** a copy of one stream into another
- **ack** a reader confirming it handled a message

Traceability: L3-05-015 to L3-05-028 (cell topology, durable state, inter-cell links, failure behaviour) and open items L3-05-O01 to L3-05-O07 (O07: telemetry on NATS against ADR-058, see LB-V3-L4-02). Parent: LB-V3-L2-01 requirements L2-016, L2-017, L2-023, L2-026. Related: LB-V3-L3-08 Regions and Residency.